Gestión de mecanismos de autenticación resistente al *phishing*

Síntesis: Mecanismos y riesgos de autenticación en servicios digitales

La autenticación segura exige comprender que identidad, identificación, autenticación y autorización son procesos relacionados, pero diferentes. Una cuenta se protege mediante credenciales y autenticadores cuya seguridad depende tanto del factor utilizado como del protocolo. Las amenazas actuales evidencian que aumentar el número de pasos no siempre resuelve el problema: las contraseñas pueden robarse o reutilizarse, los OTP pueden retransmitirse y las notificaciones pueden generar fatiga. Por esta razón, el análisis debe centrarse en propiedades verificables como vinculación con el verificador, resistencia a repetición e intención de autenticación.

La resistencia al *phishing* busca impedir que una prueba válida sea utilizada por un servicio impostor sin depender exclusivamente de que la persona reconozca el engaño. WebAuthn y los autenticadores FIDO aplican criptografía de clave pública y vinculación con la parte confiable. La selección final debe relacionarse con el impacto de una autenticación fallida y con los niveles AAL de NIST. Así, elegir un mecanismo resistente al *phishing* se convierte en un proceso de gestión del riesgo que integra necesidades del servicio, amenazas, nivel de aseguramiento, compatibilidad, usabilidad, recuperación y arquitectura.

Un enfoque integral de autenticación segura reduce riesgos y protege los servicios digitales.